AEGIS BANK

Multi-Factor Authentication (MFA) Policy

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Multi-Factor Authentication (MFA) Policy
Document ID	**AB-SEC-002**
Department	Information Security
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Information Security Department
Classification	Confidential
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Multi-Factor Authentication (MFA) Policy establishes mandatory authentication requirements for accessing Aegis Bank systems, applications, cloud services, and sensitive information.

This document is intended for authorized employees, contractors, vendors, and third-party users with approved system access.

Unauthorized disclosure or distribution of this document is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Policy Statement
4. MFA Principles
5. MFA Requirements
6. Approved Authentication Factors
7. Systems Requiring MFA
8. Administrative Access
9. Remote Access
10. Exceptions
11. Responsibilities
12. Frequently Asked Questions
13. Revision History
14. Document Approval

---

1. Purpose

The purpose of this policy is to strengthen identity verification by requiring Multi-Factor Authentication (MFA) for access to critical systems and sensitive information.

The objectives are to:

- Prevent unauthorized access.
- Reduce credential theft risks.
- Protect customer information.
- Strengthen cyber resilience.
- Meet regulatory and security requirements.
- Support Zero Trust security principles.

---

2. Scope

This policy applies to:

- Employees
- Contractors
- Consultants
- Third-party vendors
- Temporary staff
- System administrators
- Executive management

It covers:

- Corporate laptops
- Mobile devices
- Cloud platforms
- VPN connections
- Email systems
- Banking applications
- Administrative systems
- Remote desktop services
- Database administration tools

---

3. Policy Statement

All users accessing designated Aegis Bank systems must successfully complete Multi-Factor Authentication before access is granted.

MFA shall:

- Be mandatory for high-risk systems.
- Use approved authentication methods.
- Protect privileged accounts.

- Support secure remote access.
- Be enforced through centralized identity management.

Single-factor authentication is prohibited for systems classified as Critical or High Risk.

---

4. MFA Principles

The Bank's MFA program is based on the following principles:

- Identity verification before access.
- Least privilege access.
- Zero Trust architecture.
- Risk-based authentication.
- Continuous security monitoring.
- Secure identity lifecycle management.

---

5. MFA Requirements

MFA is mandatory for:

- Employee email accounts.
- VPN access.
- Cloud applications.
- Core Banking System.
- Customer Relationship Management (CRM) platforms.
- Administrative accounts.
- Financial reporting systems.
- HR management systems.
- Document Management System (DMS).
- Remote administrative sessions.

Authentication must occur before access is granted.

---

6. Approved Authentication Factors

Authentication must use at least **two different categories**.

Something You Know

Examples:

- Password
- PIN
- Passphrase

Something You Have

Examples:

- Authenticator application
- Hardware security key
- Smart card
- Secure OTP token

Something You Are

Examples:

- Fingerprint
- Facial recognition
- Iris scan

Biometric authentication may only be used on approved devices.

---

7. Systems Requiring MFA

The following systems require mandatory MFA:

System	MFA Required
Corporate Email	Yes
VPN	Yes
Core Banking Platform	Yes
Customer Portal Administration	Yes
Database Servers	Yes
Financial Reporting Platform	Yes
Cloud Infrastructure	Yes
HR Management System	Yes
DevOps Administration Tools	Yes
Security Monitoring Platform	Yes

---

8. Administrative Access

All privileged accounts require enhanced authentication controls.

Requirements include:

- MFA at every login.
- Dedicated administrator accounts.
- Session logging.
- Privileged Access Management (PAM) where implemented.
- Time-limited privileged access.
- Approval for emergency administrative access.

Shared administrator accounts are prohibited unless specifically authorized and audited.

---

9. Remote Access

All remote connections to Aegis Bank resources must use MFA.

This includes:

- VPN connections.
- Remote desktop access.
- Cloud administration.
- Third-party support access.
- Remote server management.

Connections failing MFA verification shall be denied automatically.

---

10. Policy Exceptions

Exceptions require:

- Documented business justification.
- Risk assessment.
- Approval from the Chief Information Security Officer (CISO) or authorized delegate.
- Defined expiration date.
- Periodic review.

Temporary exceptions shall be removed as soon as operationally feasible.

---

11. Roles & Responsibilities

Employees

Responsible for:

- Completing MFA enrollment.
- Protecting authentication devices.
- Reporting lost or stolen authentication devices immediately.
- Never approving unexpected MFA requests.

Managers

Responsible for:

- Ensuring team compliance.
- Reporting access requirement changes.
- Supporting security awareness.

Information Security Team

Responsible for:

- Managing MFA infrastructure.
- Monitoring authentication events.
- Investigating suspicious login attempts.
- Reviewing policy compliance.
- Approving technical configurations.

---

12. Practical Examples

Example 1 – Secure VPN Login

An employee enters a password and approves a login request through the Bank's authenticator application.

Outcome

Access is granted because both authentication factors are successfully verified.

Example 2 – Suspicious MFA Request

An employee receives an MFA approval request without attempting to log in.

Correct Action

The employee denies the request immediately and reports the incident to the Information Security Team, as it may indicate credential compromise.

Example 3 – Lost Authentication Device

A staff member loses the mobile phone used for MFA.

Correct Action

The employee reports the loss immediately. The Information Security Team disables the registered MFA device, verifies the employee's identity, and enrolls a replacement authentication method.

Example 4 – Administrator Login

A database administrator accesses a production server.

Outcome

The administrator authenticates using a password and a hardware security key. The session is logged for audit purposes.

---

13. Frequently Asked Questions (FAQs)

Q1. Is MFA mandatory for all employees?

MFA is mandatory for designated systems, including email, VPN, cloud services, and all critical banking applications.

Q2. Can SMS codes be used for MFA?

SMS-based authentication should only be used when stronger methods are not available or supported.

Q3. What happens if I lose my authentication device?

Report the loss immediately so the Information Security Team can disable the device and register a replacement.

Q4. Can employees approve unexpected MFA prompts?

No. Unexpected MFA requests must always be denied and reported immediately.

Q5. Are administrators required to use MFA?

Yes. All privileged and administrative accounts require MFA without exception unless formally approved under the Bank's exception process.

---

14. Related Documents

- Password Policy (AB-SEC-001)
- Cyber Security Policy (AB-SEC-003)
- Incident Response Plan (AB-SEC-004)
- Data Classification Policy (AB-SEC-005)
- Identity & Access Management Standard (AB-SEC-006)
- Acceptable Use Policy (AB-SEC-007)

---

15. Revision History

Version	Date	Description	Author
v1.0	January 15, 2026	Initial Release	Information Security Department
v1.1	April 18, 2026	Expanded MFA Coverage for Cloud Services and Administrative Access	Information Security Department
v1.2	**July 24, 2026**	**Added Zero Trust Principles, Hardware Security Keys, and Enhanced Remote Access Controls**	**Information Security Department**

---

16. Document Approval

Field	Details
Document ID	**AB-SEC-002**
Document Title	**Multi-Factor Authentication (MFA) Policy**

Field	Details
Department	Information Security
Version	**v1.2**
Classification	**Confidential**
Document Owner	Information Security Department
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	Information Security, IT Operations, Infrastructure Team, All Employees
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	MFA Policy v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.

.